



CYBERCLASS

Participante: Luis Ramon Reyes Volquez

Facilitador: Kevin Feliz Henríquez

Técnico: Ciberseguridad

Módulo: Seguridad Física

Actividad: Identificación de Brechas de Seguridad en Centros de Datos

Descripción: Identificamos las vulnerabilidades que pueden presentar los Centros de Datos a causa de ignorancia o falta de inversión económica en un posible DataCenter.

Link de GitHub: <https://github.com/elchecho3000-blip/Ciberseguridad-bootcamp/tree/main/Seguridad%20F%C3%ADsica>

- **1. Controles de Identidad y Recursos Humanos (Filtro Inicial)**

El atacante entró por la puerta delantera gracias a un proceso de contratación débil.

- **Investigación de antecedentes (Background Check):** Para cualquier puesto con acceso a áreas críticas (incluso personal temporal o de mantenimiento), es obligatorio un filtrado riguroso que verifique antecedentes penales, historial laboral y referencias.
- **Política de "Privilegio Mínimo" para temporales:** El personal de mantenimiento no debió tener acceso libre a los planos del edificio ni a las rutinas de seguridad de los guardias. Su acceso debe limitarse estrictamente al área y horario de su tarea específica.

• 2. Seguridad Física y Control de Accesos

El uso compartido de tarjetas y la falta de supervisión facilitaron el movimiento del intruso.

- **Autenticación Multifactor Física (MFA):** Las tarjetas magnéticas clonadas o robadas no habrían servido si el acceso al cuarto de servidores requiriera además **biometría** (huella dactilar o reconocimiento facial) o un PIN dinámico.
- **Prohibición estricta de "Tailgating" (Paso en cadena):** Compartir o prestar tarjetas debe ser motivo de sanción grave. Se debieron instalar torniquetes de altura completa o esclusas de seguridad (mantrap) que solo permiten el paso de una persona a la vez tras validar su identidad.
- **Control de bitácoras en tiempo real:** El sistema debió generar una alerta automática si la tarjeta de un empleado registraba accesos en horarios inusuales (como un fin de semana) o en dos áreas distintas al mismo tiempo.

• 3. Gestión y Monitoreo de Seguridad (CCTV y Guardias)

- Desactivar cámaras bajo el pretexto de "mantenimiento" sin un protocolo de autorización es una falla procedimental severa.
- **Protocolo de "Dos Personas" (Two-Man Rule):** Ningún operador o técnico debe poder apagar un sistema de seguridad por sí solo. El apagado de cámaras debió requerir la firma digital y presencia física del director de seguridad y un supervisor.
- **Monitoreo espejo o redundante:** Si las cámaras se apagan por mantenimiento, el personal de seguridad física debe desplegar **guardias presenciales** para custodiar activamente esa zona ciega mientras dure el procedimiento.
- **Alertas por pérdida de señal:** El sistema de videovigilancia debe emitir una alarma sonora de alta prioridad en el centro de control si una cámara crítica pierde conexión de forma inesperada.

4. Seguridad de los Datos e Infraestructura TI

Los atacantes se llevaron "servidores portátiles" con datos limpios y listos para leer.

- **Cifrado en Reposo (Encryption at Rest):** Si los datos hubieran estado cifrados mediante hardware o software, los servidores robados habrían sido inútiles para los criminales. Al encenderlos en otro lugar, solo verían caracteres ilegibles sin la clave maestra.
- **Bloqueo físico de hardware (Locks & Cages):** Los servidores críticos no deben estar sueltos. Debieron estar atornillados a racks cerrados con llave dentro de jaulas de seguridad de alta resistencia.
- **Deshabilitar puertos físicos:** Las bahías de expansión y los puertos USB/removibles de los servidores deben estar bloqueados físicamente o desactivados por software para evitar que se conecten periféricos no autorizados.

Lo aprendido:

El verdadero fallo de DataSecureCorp fue la confianza ciega en la tecnología básica. Asumieron que tener cámaras y tarjetas era suficiente, olvidando que los procedimientos humanos son el eslabón más débil. La seguridad efectiva requiere que la tecnología, los procesos y las personas actúen como un engranaje unificado donde nadie pueda saltarse las reglas de control.